

TradesFlow Technical Specifications

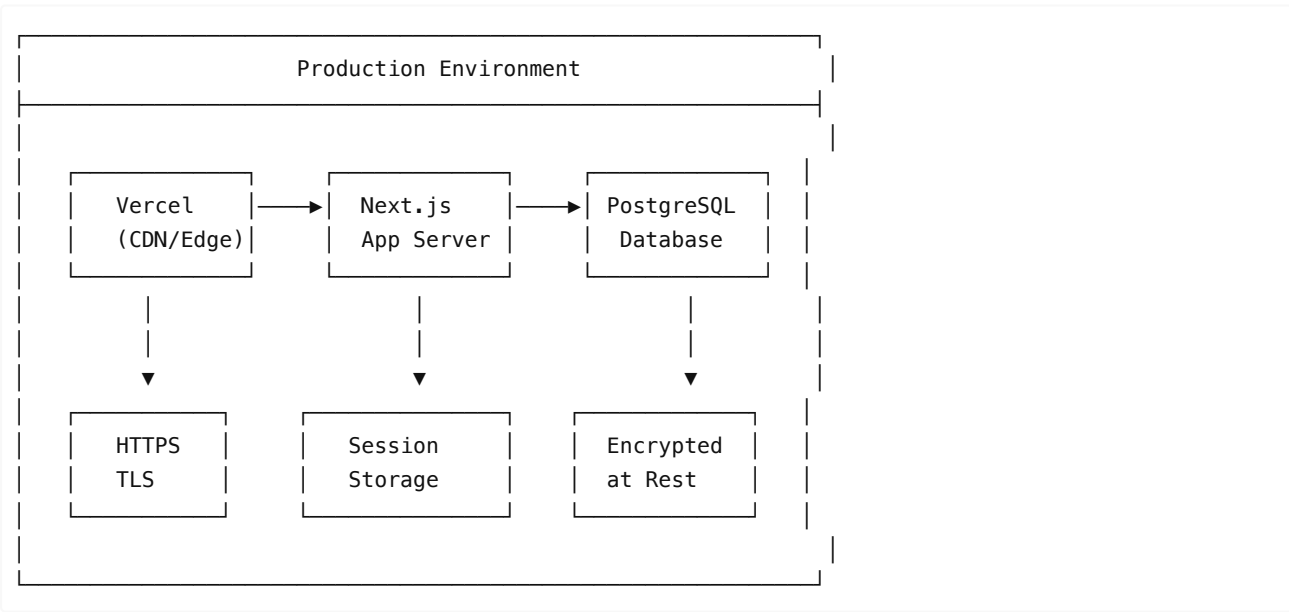
For IT and Security Reviewers

Architecture Overview

Technology Stack

Layer	Technology	Version
Frontend	Next.js	14.2.3
UI Framework	React	18.3.1
Styling	Tailwind CSS	3.4.3
Database	PostgreSQL	Latest
ORM	Prisma	5.14.0
Authentication	NextAuth.js	4.24.7
Password Hashing	bcryptjs	2.4.3
SMS Provider	Twilio	5.0.4
Validation	Zod	3.23.8
Language	TypeScript	5.4.5

Deployment Architecture



Authentication System

Implementation Details

Component	Implementation
-----------	----------------

Provider	Credentials (email/password)
Session Strategy	JWT
Session Duration	30 days
Password Storage	bcrypt (12 rounds)
Token Storage	HTTP-only cookies

Session Management

```
session: {
  strategy: 'jwt',
  maxAge: 30 * 24 * 60 * 60, // 30 days
}
```

JWT Token Contents

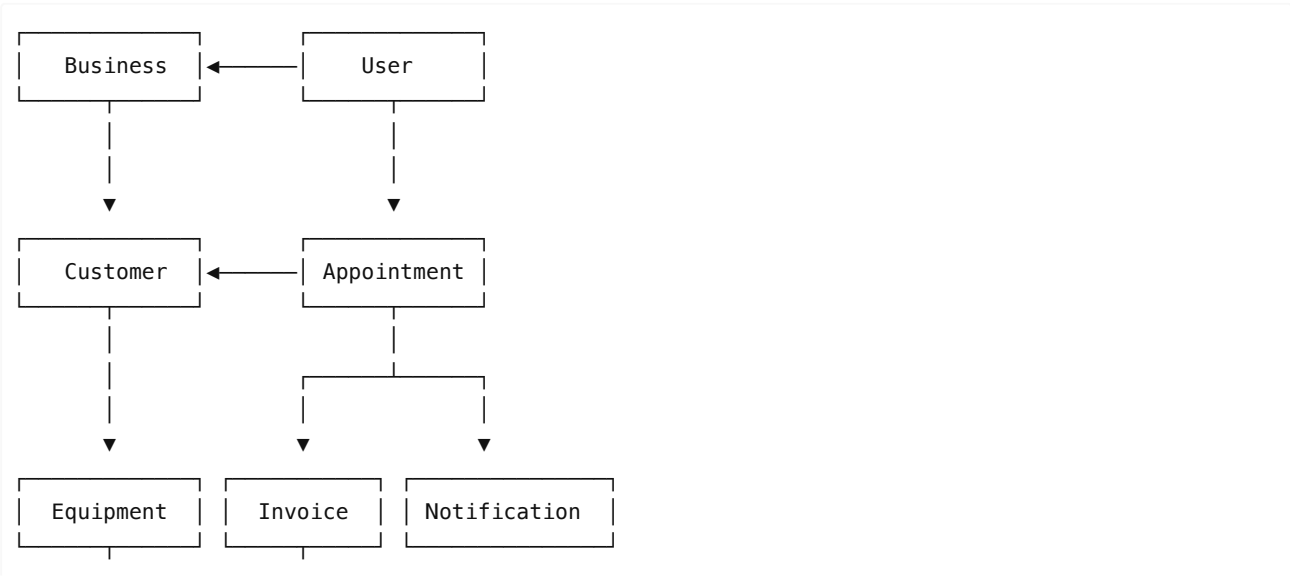
Claim	Description
id	User unique identifier
email	User email address
role	OWNER
businessId	Business context for multi-tenancy

Password Security

- **Algorithm:** bcrypt
- **Cost Factor:** 12 rounds
- **Minimum Length:** Enforced by validation
- **Requirements:** Email + password required

Data Model

Entity Relationship Diagram





Core Models

User

Field	Type	Description
id	String (CUID)	Unique identifier
email	String	Login email (unique)
password	String	bcrypt hash
name	String	Display name
role	Enum	OWNER, ADMIN, TECHNICIAN
isActive	Boolean	Account status
businessId	String	Business association

Business

Field	Type	Description
id	String (CUID)	Unique identifier
name	String	Business name
slug	String	URL-safe identifier (unique)
phone	String	Business phone
timezone	String	Business timezone
primaryColor	String	Brand color (default: #3B82F6)

Customer

Field	Type	Description
id	String (CUID)	Unique identifier
name	String	Customer name
phone	String	Contact phone
email	String?	Contact email (optional)
address	String?	Service address
businessId	String	Business association

Equipment

Field	Type	Description
id	String (UUID)	Unique identifier
type	Enum	HVAC, PLUMBING, ELECTRICAL, APPLIANCE, ROOFING, OTHER
brand	String?	Manufacturer
model	String?	Model number
serialNumber	String?	Serial number
installDate	DateTime?	Installation date
warrantyExpires	DateTime?	Warranty expiration
photos	String[]	Photo URLs
customerId	String	Customer association

API Structure

Planned REST Endpoints

Note: API development is ongoing. Current endpoints support web application.

Authentication

Method	Endpoint	Description
POST	/api/auth/signup	Create new account
POST	/api/auth/signin	Authenticate user
POST	/api/auth/signout	End session
GET	/api/auth/session	Get current session

Customers (Wave 2)

Method	Endpoint	Description
GET	/api/customers	List customers
POST	/api/customers	Create customer
GET	/api/customers/:id	Get customer details
PUT	/api/customers/:id	Update customer
DELETE	/api/customers/:id	Delete customer

Appointments (Wave 3)

Method	Endpoint	Description
GET	/api/appointments	List appointments
POST	/api/appointments	Create appointment

GET	/api/appointments/:id	Get appointment
PUT	/api/appointments/:id	Update appointment
PATCH	/api/appointments/:id/status	Update status

Invoices (Wave 4)

Method	Endpoint	Description
GET	/api/invoices	List invoices
POST	/api/invoices	Create invoice
GET	/api/invoices/:id	Get invoice
PUT	/api/invoices/:id	Update invoice
POST	/api/invoices/:id/send	Send invoice

Equipment (Wave 5)

Method	Endpoint	Description
GET	/api/equipment	List equipment
POST	/api/equipment	Create equipment
GET	/api/equipment/:id	Get equipment
PUT	/api/equipment/:id	Update equipment
POST	/api/equipment/:id/photos	Upload photos

Hosting & Infrastructure

Current Setup

Component	Provider	Configuration
Application Hosting	Vercel	Serverless functions
Database	Managed PostgreSQL	Encrypted at rest
File Storage	Cloud storage	Encrypted
CDN	Vercel Edge	Global distribution
SMS	Twilio	US numbers

Scalability

- **Horizontal Scaling:** Vercel handles automatically
- **Database:** Can scale vertically; read replicas available
- **File Storage:** Unlimited with cloud provider
- **Rate Limiting:** Per-endpoint limits configured

Data Privacy & Ownership

Data Collection

Data Type	Purpose	Retention
User credentials	Authentication	Account lifetime
Business info	Account management	Account lifetime
Customer data	Service delivery	Account lifetime + 30 days
Equipment records	Service history	Account lifetime
Appointment data	Scheduling	Account lifetime + 1 year
Invoice data	Financial records	Account lifetime + 7 years

Data Ownership

- **You own your data:** All business data belongs to you
- **Export available:** Full data export on request
- **Deletion on request:** Data deleted within 30 days of account closure
- **No data selling:** We never sell your data to third parties

Access Controls

Role	Customer Data	Business Data	User Data
Owner	Full	Full	Full
Admin	Full	Limited	Own only
Technician	Assigned jobs	None	Own only

Security Measures

In Transit

- HTTPS/TLS 1.3 for all connections
- HSTS headers enforced
- Secure cookie flags (httpOnly, secure, sameSite)

At Rest

- Database encryption enabled
- File storage encryption
- Backups encrypted

Authentication

- bcrypt password hashing (12 rounds)
- JWT tokens with short expiry
- Session invalidation on password change
- Brute force protection (rate limiting)

Application

- Input validation on all endpoints (Zod)
 - SQL injection prevention (Prisma parameterized queries)
 - XSS prevention (React automatic escaping)
 - CSRF protection (SameSite cookies)
-

Backup & Recovery

Backup Strategy

Type	Frequency	Retention
Full database	Daily	30 days
Transaction logs	Continuous	7 days
File storage	Daily	30 days

Recovery

- **RTO (Recovery Time Objective):** < 4 hours
 - **RPO (Recovery Point Objective):** < 1 hour
 - **Geographic redundancy:** Yes
 - **Disaster recovery plan:** Documented and tested
-

Monitoring & Observability

Current Monitoring

- Application health checks
- Error tracking and alerting
- Performance monitoring
- Uptime monitoring

Alerting

- Critical errors: Immediate notification
 - Performance degradation: < 5 minute detection
 - Security events: Real-time alerts
 - Capacity thresholds: Proactive warnings
-

Compliance Roadmap

Standard	Status	Target
GDPR (Data Export/Deletion)	Partial	Q2 2026
SOC 2 Type I	Not started	2026
SOC 2 Type II	Not started	2027
HIPAA	N/A	Not planned

Integration Capabilities

Current

Integration	Method	Notes
Twilio	API	SMS notifications
Email	SMTP/API	Transactional emails

Planned (2026)

Integration	Method	ETA
Stripe	API	Q2 2026
QuickBooks	API	Q3 2026
Zapier	Webhook	Q4 2026
Custom API	REST	Q4 2026

Technical Support

For IT Teams

- **Documentation:** Technical docs available
- **API Status:** Status page for uptime monitoring
- **Security Inquiries:** security@tradesflow.com
- **Enterprise Support:** Dedicated channel for Enterprise customers

Onboarding Assistance

- CSV data import support
 - User provisioning guidance
 - SSO setup (Enterprise)
 - Custom integration consultation
-

Questions?

Technical Inquiries: support@tradesflow.com **Security Concerns:** security@tradesflow.com **Enterprise IT Review:** enterprise@tradesflow.com

This document is updated as the platform evolves. Last updated: March 2026. For the most current technical information, contact our team.